

# Report Password Cracking

## S6L4

### 1. Obiettivo

L'obiettivo dell'esercitazione è duplice: recuperare le password hashate presenti nel database della DVWA (Damn Vulnerable Web Application) su Metasploitable 2 tramite cracking offline degli hash MD5 con **John the Ripper**, e successivamente eseguire un attacco di brute force sul form di login HTTP della DVWA tramite **Hydra**, dimostrando due approcci distinti al password cracking.

**Nota:** Gli attacchi di password cracking mirano a recuperare credenziali in chiaro da hash o da servizi di autenticazione. L'esercitazione è svolta esclusivamente in ambiente controllato a fini didattici. Nessuna tecnica è stata applicata su sistemi reali.

### 2. Configurazione dell'Ambiente

| Macchina         | Ruolo      | IP           | Tool                              |
|------------------|------------|--------------|-----------------------------------|
| Kali Linux       | Attaccante | 192.168.5.19 | MySQL CLI, John the Ripper, Hydra |
| Metasploitable 2 | Bersaglio  | 192.168.5.20 | MySQL (3306), DVWA HTTP (80)      |

### 3. Parte 1 : Cracking degli Hash MD5 con John the Ripper

#### Step 1 - Accesso al Database MySQL

Da Kali Linux è stato effettuato l'accesso diretto al database MySQL di Metasploitable. Il flag **--ssl=0** è necessario per disabilitare TLS, incompatibile con la versione legacy del server MySQL su Metasploitable 2.

```
mysql -u root -p -h 192.168.5.20 --ssl=0
```

**Nota:** Senza il flag **--ssl=0** MySQL restituisce ERROR 2026 (HY000): TLS/SSL error: wrong version number, in quanto il client moderno tenta di negoziare TLS con un server che non lo supporta.

## Step 2 - Estrazione degli Hash

Una volta connessi, è stata eseguita una query per estrarre utenti e password hashate dal database dvwa. Gli hash sono di tipo MD5 (32 caratteri esadecimali).

```
USE dvwa;  
SELECT user, password FROM users;
```

Export su file per il cracking offline:

```
mysql -u root -p -h 192.168.5.20 --ssl=0 -e "USE dvwa; SELECT password FROM  
users;" > h mysql -u root -p -h 192.168.5.20 --ssl=0 -e "USE dvwa; SELECT  
user,password FROM users;
```

## Step 3 - Cracking con John the Ripper

John the Ripper è un tool di password cracking offline: opera sugli hash senza connessione di rete. Ha utilizzato la wordlist integrata (/usr/share/john/password.lst) e la modalità incrementale, crackando tutti e 5 gli hash in pochi secondi.

```
john --format=raw-md5 hashes.txt  
john --show --format=raw-md5 hashes_full.txt
```

## Output John the Ripper

```
Loaded 5 password hashes with no different salts (Raw-MD5 [MD5 128/128 ASIMD  
4x2]) password (?)  
abc123  
(?)  
letmein (?)  
charley (?)  
5g 0:00:00:00 DONE - Session completed.
```

| Utente  | Hash MD5                         | Password in Chiaro |
|---------|----------------------------------|--------------------|
| admin   | 5f4dcc3b5aa765d61d8327deb882cf99 | password           |
| gordonb | e99a18c428cb38d5f260853678922e03 | abc123             |
| 1337    | 8d3533d75ae2c3966d7e0d4fcc69216b | charley            |
| pablo   | 0d107d09f5bbe40cade3de5c71e9e9b7 | letmein            |
| smithy  | 5f4dcc3b5aa765d61d8327deb882cf99 | password           |

**Dato chiave:** admin e smithy condividono lo stesso hash (5f4dcc3b5aa765d61d8327deb882cf99) - stessa password. Senza salt, hash identici rivelano immediatamente utenti con password uguali.

## 4. Parte 2 - Brute Force HTTP con Hydra

Hydra è un tool di brute force su servizi di rete. A differenza di John the Ripper che opera offline sugli hash, Hydra attacca direttamente il form di login HTTP della DVWA, inviando combinazioni di credenziali fino a trovare quelle corrette.

**Differenza chiave:** John the Ripper cracca hash offline (nessuna connessione di rete). Hydra esegue brute force su servizi di rete attivi (HTTP, SSH, FTP, ecc.).

### Comando Hydra - HTTP POST Form

```
hydra -L username.txt -P /usr/share/wordlists/rockyou.txt 192.168.5.20
http-post-form "/dvwa/login.php:username=^USER^&password=^PASS^&Login=Login:F=Login
fai
```

### Anatomia del comando

| Parametro       | Valore             | Descrizione                                |
|-----------------|--------------------|--------------------------------------------|
| -L username.txt | Lista utenti       | File con gli username da testare           |
| -P rockyou.txt  | Wordlist           | Dizionario di password comuni              |
| 192.168.5.20    | IP target          | Indirizzo Metasploitable                   |
| http-post-form  | Modulo             | Tipo di attacco: form HTTP POST            |
| ^USER^/^PASS^   | Placeholder        | Sostituiti con user/pass ad ogni tentativo |
| F=Login failed  | Stringa fallimento | Indica risposta di login non riuscito      |

Hydra ha testato fino a **28.688.923 tentativi/minuto** con 16 task paralleli, identificando le credenziali valide in pochi minuti:

```
[80][http-post-form] host: 192.168.5.20 login: admin    password: password
[80][http-post-form] host: 192.168.5.20 login: gordonb password: abc123
[STATUS] 28688923.00 tries/min, 16 active
```

| Host         | Username | Password |
|--------------|----------|----------|
| 192.168.5.20 | admin    | password |
| 192.168.5.20 | gordonb  | abc123   |

## 5. Confronto tra i Tool Utilizzati

| Caratteristica   | John the Ripper     | Hydra                     |
|------------------|---------------------|---------------------------|
| Tipo di attacco  | Offline (hash)      | Online (servizio di rete) |
| Connessione rete | Non richiesta       | Richiesta                 |
| Input            | File di hash        | IP + endpoint + form      |
| Velocità         | Milioni di hash/sec | ~28M tentativi/min        |
| Rilevabilità     | Non rilevabile      | Rilevabile nei log HTTP   |

| Caratteristica | John the Ripper     | Hydra                     |
|----------------|---------------------|---------------------------|
| Caso d'uso     | Hash estratti da DB | Login form, SSH, FTP, RDP |

## 6. Flusso Completo dell'Esercitazione

| # | Fase                  | Tool            | Risultato                          |
|---|-----------------------|-----------------|------------------------------------|
| 1 | Connessione DB MySQL  | mysql CLI       | Accesso a dvwa.users               |
| 2 | Estrazione hash MD5   | mysql CLI       | 5 hash salvati in hashes.txt       |
| 3 | Cracking hash offline | John the Ripper | 5/5 password crackate              |
| 4 | Brute force HTTP form | Hydra           | admin:password, gordonb:abc123     |
| 5 | Verifica risultati    | john --show     | Match utente → password confermato |

## 7. Conclusioni

L'esercitazione ha dimostrato in modo pratico due approcci distinti al password cracking, evidenziando le debolezze di MD5 senza salt e di password comuni.

| Aspetto           | Osservazione                                                |
|-------------------|-------------------------------------------------------------|
| Algoritmo MD5     | Obsoleto e insicuro - non usare per storage password        |
| Assenza di salt   | Hash identici per password uguali - vulnerabilità immediata |
| Forza password    | password, abc123, letmein - presenti in qualsiasi wordlist  |
| John the Ripper   | 5/5 hash crackati in secondi senza wordlist esterna         |
| Hydra             | ~28M tentativi/min - credenziali trovate in pochi minuti    |
| Contromisura hash | bcrypt / Argon2 / PBKDF2 con salt casuale                   |
| Contromisura form | Rate limiting, CAPTCHA, account lockout                     |

**DISCLAIMER:** Tutte le tecniche, i tool e i contenuti descritti in questo documento sono stati utilizzati esclusivamente a fini didattici nell'ambito del corso Epicode Cybersecurity Bootcamp. L'esercitazione è stata svolta esclusivamente in ambiente virtuale controllato. L'utilizzo non autorizzato di tecniche di password cracking è illegale ai sensi del Codice Penale italiano (art. 615-ter, 635-bis, 617-quater).